

KESTRELATTICE

Governed Agent Mesh | Micro-Product

Pre-Deploy Safety Checklist

The last gate before an agent goes live: identity, grants, ceilings, logging, owner. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

Instant delivery | Yours to keep, forever.

PRE-DEPLOY SAFETY CHECKLIST

For AI Agents in Production Environments Version 1.0 | Governance & Risk Mitigation Framework

1. AGENT SCOPE & DEPLOYMENT CONTEXT

(Define boundaries, permissions, and operational constraints before deployment.)

Field	Requirement	Verification Method
Agent Name	Unique identifier (e.g., Finance_Agent_v2.3).	Review deployment manifest.
Purpose	Core function (e.g., "Automated fraud detection in transaction logs," "Customer support triage for Tier 1 inquiries").	Cross-reference with stakeholder approvals.
Owner Team	Primary department (e.g., Risk Compliance, Customer Success).	Check Slack/MS Teams governance channel or Jira ticket.
Deployment Environment	Production, staging, or sandbox?	Verify via environment tags in CI/CD pipeline.
Data Sources	Inputs (e.g., CRM, ERP, raw logs) and their sensitivity level (PII, financial, proprietary).	Audit data access logs pre-deployment.
Output Sensitivity	Classify outputs (e.g., "Confidential," "Public," "Internal Only").	Review output routing rules in governance policy.
Geographic Scope	Jurisdictions covered (e.g., GDPR, CCPA, HIPAA).	Confirm compliance matrices are updated.
Concurrency Limits	Max simultaneous requests (e.g., "100 QPS per user").	Set rate limits in API gateway or orchestration layer.
SLA Requirements	Response time (e.g., "95% < 2s for critical queries").	Benchmark against baseline metrics.
Deprecation Plan	Scheduled retirement date or version upgrade cadence.	Document in release notes.

2. PERMISSIONING & ACCESS CONTROLS

(Ensure least-privilege access and auditability.)

Field	Requirement	Verification Method
Role-Based Access	Define roles (e.g., ReadOnly, Execute, Admin) with granular permissions.	Test via RBAC simulator or role assignment logs.
API Key Rotation	Keys must rotate every 30 days (or per security policy).	Check key expiration dates in secrets manager (e.g., HashiCorp Vault).

Field	Requirement	Verification Method
Input Validation	Reject malformed/payload attacks (e.g., SQLi, LLM prompt injection).	Run OWASP ZAP or similar on sample inputs.
Output Sanitization	Strip or mask sensitive data in responses (e.g., ****-****-1234 for CC numbers).	Review sample outputs with data masking enabled.
Audit Logs	All actions logged with timestamps, user/agent ID, and context (e.g., "Agent Finance_Agent executed transfer() on account 12345 at 14:30:00 UTC").	Query logs via SIEM (e.g., Splunk, Datadog).
Permission Revisions	Change logs for roles/permissions versioned (e.g., Git commit history).	Verify via Git or equivalent.
Emergency Override	Define escalation path for critical overrides (e.g., kill_switch API endpoint).	Test override mechanism with security team.
Third-Party Integrations	Vendor contracts include SLAs for data protection (e.g., "No subprocessing without consent").	Attach signed NDAs to deployment artifacts.

3. COST & RESOURCE CONTROLS

(Prevent runaway spend or resource exhaustion.)

Field	Requirement	Verification Method
Budget Alerts	Set spend limits (e.g., "\$500/day per agent") with alerts at 80% threshold.	Configure in cloud provider (AWS Budgets, GCP Billing Alerts).
Token Limits	Cap API calls (e.g., "Max 100k tokens/day per user").	Enforce via API gateway or orchestration layer.
Resource Quotas	CPU/memory limits (e.g., "No agent exceeds 8GB RAM").	Set via Kubernetes HPA or cloud auto-scaling policies.
Cold Start Mitigation	Guarantee response time < 5s for 99% of requests (account for initialization delays).	Load-test with synthetic traffic.
Cost Review Process	Monthly review of spend by finance team.	Attach cost report to governance dashboard.
Auto-Shutdown	Agents pause after 12 hours of inactivity (or per policy).	Test idle timeout in staging.
Deprecation Cost	Document cleanup costs (e.g., "Deleting 1M records = \$200").	Include in risk assessment.

4. INCIDENT RESPONSE & ROLLBACK

(Define containment, notification, and recovery procedures.)

Field	Requirement	Verification Method
Incident Escalation	Tiered response (e.g., Tier 1: DevOps, Tier 2: Security, Tier 3: Legal).	Test via war-gaming exercise.
Kill Switch	Immediate halt via API or manual trigger (documented in runbook). Revert to last known good version within 15 minutes of incident.	Verify kill switch endpoint returns 200 OK with status: "halted".
Rollback Plan	Standardized report format (e.g., "Root cause," "Impact," "Corrective actions").	Review past incidents for template compliance.
Post-Mortem Template	Vendors notified within 1 hour of material breach (e.g., data leak).	Confirm in vendor contracts.
Third-Party Notifications	No public statements until incident response team approves.	Add to crisis communication plan.
Media Blackout	Retain raw logs for 90 days post-incident (per compliance). Conduct quarterly drills (e.g., "Agent hallucinates PII in response").	Verify log retention policies.
Forensic Logging		Document exercise outcomes.
Tabletop Exercises		

5. COMPLIANCE & AUDIT TRAILS

(Ensure regulatory adherence and traceability.)

Field	Requirement	Verification Method
GDPR/CCPA/HIPAA	Data subject rights (DSRs) handled via agent (e.g., "Right to erasure").	Test DSR workflow with sample requests.
Data Retention	Delete sensitive data after 180 days (or per policy).	Schedule purge jobs in cron.
Export Logs	Ability to export audit logs to SIEM (e.g., CSV/JSON).	Test export via API.
Compliance Officer	Named point of contact for audits (e.g., compliance@company.com).	Verify contact is in governance docs.
Vendor Audits	Allow third-party audits of agent code/data flows.	Document audit access procedures.
Change Log	Track all modifications (e.g., "2024-05-15: Updated transfer() logic to include 2FA").	Version-control changes in Git.

Field	Requirement	Verification Method
Regulatory Updates	Alerts for new laws (e.g., AI Act, state-level bans).	Subscribe to compliance feeds (e.g., LexisNexis).
Training Data	Document sources of training data (e.g., "Publicly available financial reports, no PII").	Attach provenance report.

6. PERFORMANCE & RELIABILITY

(Ensure consistency, accuracy, and observability.)

Field	Requirement	Verification Method
Accuracy SLA	Error rate < 1% on validation dataset (e.g., "99% precision for fraud flags").	Run A/B test against human baseline.
Latency P99	Response time < 3s for 99% of requests.	Monitor via Prometheus/Grafana.
Error Handling	Graceful degradation (e.g., "Fallback to cached response if LLM fails").	Test failure modes in staging.
Monitoring Alerts	Anomaly detection (e.g., "Error rate spikes > 5%").	Configure in Datadog/New Relic.
Canary Deployments	New versions roll out to 5% traffic first.	Verify via feature flags.
Drift Detection	Alert if agent output deviates from baseline (e.g., "Hallucination rate > 0.5%").	Use tools like Arize or MLflow.
Backup Plan	Point-in-time restore for critical data.	Test restore procedure.
Disaster Recovery	Cross-region failover for cloud-hosted agents.	Verify RTO/RPO metrics.

7. DOCUMENTATION & HANDOFF

(Ensure operational clarity and knowledge transfer.)

Field	Requirement	Verification Method
Runbook	Step-by-step for common operations (e.g., "How to restart the agent").	

KESTRELATTICE

The governed agent mesh for production AI.

kestrelattice.com